Lab 46 — Risk Register, CVSS Scoring, and Quantitative Risk

> **SY0-701 Objective 5.2** — Explain elements of the risk management process
>
> **Domain 5** — Security Program Management and Oversight (20%) · **Time:** ~20 min · **Course:** C628 CompTIA Security+ Exam Prep

Goal: Build a working risk register and justify a control with hard numbers.

You'll build: A CSV risk register, a CVSS v3.1 score for the top finding, the SLE/ALE maths behind it, a set of key risk indicators and a one-page board report.

Prerequisites: Killercoda Ubuntu Playground (root shell) — https://killercoda.com/playgrounds/scenario/ubuntu ; `python3` (pre-installed); a browser for the FIRST CVSS calculator.

Background

- A **risk register** is a management tool, not a scan dump: every row needs an ID, an owner, a treatment decision and a status.
- **Qualitative** analysis rates risk High/Medium/Low; **quantitative** analysis attaches money using SLE, ARO and ALE.
- `SLE = AV x EF` (loss per event) and `ALE = SLE x ARO` (loss per year) — spend on a control only up to the ALE it removes.
- **CVSS** scores a vulnerability's technical severity 0.0–10.0; it ranks findings but does not by itself set business priority.
- **Key risk indicators (KRIs)** are leading metrics with a threshold that escalates to the named risk owner.

Steps

1. Create and view the CSV risk register

Each column maps to an element of objective 5.2: identification, likelihood, impact, owner, strategy.

```
mkdir -p ~/grc && cd ~/grc
cat > risk-register.csv <<'EOF'
id,asset,threat,vuln,likelihood,impact,owner,strategy,status
R-001,web-prod,SQL injection,unsanitised input,High,High,webops,Mitigate,Open
R-002,db-prod,Ransomware,no off-site backup,Medium,Critical,dbops,Mitigate,Open
R-003,laptop-fleet,Theft,no FDE,High,Medium,it,Mitigate,In-progress
R-004,mail,Phishing,no DMARC reject,High,High,security,Mitigate,Open
R-005,legacy-app,Vendor EOL,no patches,Low,High,procurement,Transfer,Accepted
EOF
column -t -s, risk-register.csv
```

2. Score R-001 on the FIRST.org CVSS v3.1 calculator

Open https://www.first.org/cvss/calculator/3.1 and set AV:N, AC:L, PR:N, UI:N, S:U, C:H, I:H, A:H.

```
Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H
Base score: 9.8 (Critical)
```

3. Compute SLE and ALE in Python

Turn the top risk into a money figure the business understands.

```
cd ~/grc
python3 - <<'EOF'
AV, EF, ARO = 200000, 0.6, 0.5   # value, exposure factor, events/year
SLE = AV * EF
ALE = SLE * ARO
print(f"SLE = {SLE:,.0f} per event")
print(f"ALE = {ALE:,.0f} per year")
print(f"Spend up to {ALE:,.0f} on a control to break even.")
EOF
```

4. Choose a risk treatment (mitigate vs accept)

Compare the cost of the control against the ALE it removes.

```
R-001: ALE 60,000/yr  vs  WAF control ~5,000/yr  ->  MITIGATE (control << ALE)
R-005: patch cost > benefit, low likelihood       ->  TRANSFER / ACCEPT (signed off)
```

Transfer moves the financial loss (insurance); it does not remove the risk. Avoid removes the activity entirely.

5. Add Key Risk Indicators to a CSV

KRIs are leading signals with a threshold that triggers action.

```
cd ~/grc
cat > kri.csv <<'EOF'
risk_id,indicator,threshold,current,status
R-001,WAF block rate,>0/day,124/day,Green
R-002,Days since off-site backup,<7,2,Green
R-003,Laptops without FDE,<5%,12%,Red
R-004,DMARC policy,=reject,quarantine,Amber
EOF
column -t -s, kri.csv
```

6. Generate the one-page board risk report

Reporting translates the register into a decision for leadership.

```
cd ~/grc
python3 - > board-report.md <<'EOF'
print("# Quarterly Risk Report")
print("- Open risks: 4 (1 Critical, 2 High, 1 Medium)")
print("- Top exposure: R-001 SQLi, ALE 60,000/yr, CVSS 9.8")
```

```
print("- Recommended spend: 35,000 across top 4 (all < their ALE)")
print("- Accepted: R-005 (signed off by risk owner, review in 6 months)")
EOF
cat board-report.md
```

Test it

```
cd ~/grc
python3 -c "print('ALE =', 200000*0.6*0.5)"
cat board-report.md
```

Expected: the Python output shows `ALE = 60000.0` per year, and `board-report.md` lists the open risks, the top exposure and the recommended spend.

Troubleshooting

Symptom	Fix
`column: command not found`	Install it: `apt-get install -y bsdmainutils`.
CVSS calculator shows a different score	Re-check the metric values — a single changed metric moves the base score.
Board report is empty	The heredoc delimiter must be alone on its line; re-run step 6 exactly.

Challenge

Add a sixth risk of your own, score it in qualitative terms, then convert it to a quantitative ALE with your own AV, EF and ARO assumptions.

Reflection

Objective 5.2 separates qualitative and quantitative analysis. For R-001, which did the board report rely on to justify the spend, and why was a CVSS score alone not enough?

Exam tips

- `SLE = AV x EF`; `ALE = SLE x ARO`. Be ready to compute ALE in one step from AV, EF and ARO.
- Transfer (insurance) moves the financial loss but not the risk; avoid removes the activity.
- A risk register entry is incomplete without a named owner, a treatment and a review date.
- CVSS ranks technical severity; business context (asset value) decides real priority.

References

- FIRST CVSS v3.1 calculator — https://www.first.org/cvss/calculator/3.1
- NIST SP 800-30 risk assessment — https://csrc.nist.gov/pubs/sp/800/30/r1/final
- NIST SP 800-37 risk management framework — https://csrc.nist.gov/pubs/sp/800/37/r2/final

---